

Vulnerability Assessment Report

Cible : Google Gruyere

Date : Mai 2026

Auteur : Whitney El Aquilas Mfouo Mbela

Outils : Nmap, OWASP ZAP (mode passif), DevTools, Canva

Executive Summary

A passive security assessment was conducted on the Google Gruyere web application. Four vulnerabilities were identified: two rated Medium risk (missing security headers) and two rated Low risk (insecure cookie flags, internal comments in HTML). No critical vulnerabilities (e.g., remote code execution, SQL injection) were found within the scope of this passive analysis.

The recommended fixes are simple to implement (adding HTTP headers, hardening cookies). After applying the fixes, the residual risk would be negligible.

Scope & Methodology

Item	Description
Target	https://google-gruyere.appspot.com/
Test type	External, passive (no active attacks)
Tools	Nmap, OWASP ZAP, DevTools
Scope	Publicly accessible pages after simple registration
Date	May 2026

Limitations: No active exploitation was performed. The analysis is based on HTTP headers, cookies, and source code review.

Summary Table

Vulnerability	Risk	Quick Fix
Missing X-Frame-Options	Medium	Add SAMEORIGIN
Missing HSTS	Medium	Enable Strict-Transport-
Cookie without Secure flag	Low	Security Add Secure,
Internal HTML comments	Low	HttpOnly Remove debug comments

Finding 1: Missing X-Frame-Options

Title: Missing Anti-Clickjacking Header (X-Frame-Options)

Risk Level: Medium

Technical description: The server does not return the X-Frame-Options header. The site can be embedded in an invisible iframe.

Business impact: An attacker can trick users into unauthorized actions.

Remediation: Add: X-Frame-Options: SAMEORIGIN

Finding 2: Missing HSTS

Title: Missing HSTS Header (Strict-Transport-Security)

Risk Level: Medium

Technical description: The Strict-Transport-Security header is absent.

Business impact: Attackers may intercept traffic using SSL stripping.

Remediation: Add HSTS with max-age=31536000

Finding 3: Cookie Without Secure Flag

Title: Session Cookie Without Secure Flag

Risk Level: Low

Technical description: The session cookie is set without the Secure attribute.

Business impact: Cookies may be intercepted over HTTP.

Remediation: Add Secure, HttpOnly, SameSite attributes

Finding 4: Internal Comments in HTML

Title: Internal Comments in HTML Code

Risk Level: Low

Technical description: HTML source code contains development comments.

Business impact: Attackers gain intelligence about internal logic.

Remediation: Remove comments from production

Nmap Results

Port	Service	Information
21/tcp	FTP	Active FTP server
80/tcp	HTTP	F5 BIG-IP load balancer
443/tcp	HTTPS	Apache 2.4.67 – valid SSL certificate
8080/tcp	HTTP-Proxy	Application Error page

The presence of FTP and port 8080 expands the attack surface. The SSL certificate is valid, which is a positive point.

General Recommendations & Conclusion

General Recommendations

1. HTTPS everywhere – Redirect all HTTP traffic to HTTPS and enable HSTS.
2. Add security headers such as X-Frame-Options and CSP.
3. Harden cookies with Secure, HttpOnly, and SameSite.
4. Remove debug comments from production.
5. Re-run passive ZAP scans regularly.

Conclusion

The Google Gruyere application presents Medium and Low risk vulnerabilities, mostly related to missing security headers and insecure cookie settings. No critical flaws were detected. Applying the recommended fixes would significantly reduce the risk of session hijacking and clickjacking.

Security Analyst: Whitney El Aquilas

Report Date: May 2026